

Test Report — A user may delete only their own cards

PR: kuantorflow#173 (+ kuantorflow_automation#36) · Issue: kuantorflow#162 · Date: 2026-08-02

Summary

Card deletion is now bound to ownership: the admin deletes anything, a signed-in user deletes only their own cards, an anonymous visitor deletes nothing. Verified against the real local database as four different identities, including forged POSTs that the UI never offers. This closes a real hole — until now the delete route had **no identity check at all**.

What changed

- `utils.delete_flashcard(card_id, owner_id=None, admin=False)` returns (word, outcome) with outcome deleted / denied / missing. The removal is **one conditional statement** (`WHERE id = %s AND added_by_user_id = %s`), so there is no gap between deciding a card is yours and taking it; the word is read first only so the caller has something to say.
- `app.delete_card()` enforces the rule **in the route**. Greying the cross is presentation; a hand-made POST goes straight past it.
- Anonymous visitors (and sign-ins with no users row, #148) are refused before the database is touched, with #125's sign-in prompt rather than #162's "someone else's card".
- `applog.card_delete_denied()` writes DELETE-DENIED with the card id, the acting user and a reason (not owner / anonymous).
- `templates/flashcards.html`: the cross stays on every card, greyed with `aria-disabled="true"` and a title tooltip when the card is not yours. **`aria-disabled`, not `disabled`** — an inert control's hover and tooltip behaviour varies by browser, where this stays hoverable and focusable everywhere and leaves the refusal to the click handler.
- A second, informational modal (single **OK**) shows the same sentence on tap, since touch devices never see a title tooltip.
- CSS: the greyed cross is muted with `cursor: default`, and the red `.card-delete:hover` state is explicitly suppressed — a cross you cannot use must not light up as if you could.

Automated tests

- **Added:** `tests/test_card_deletion_rules.py` — 23 tests: the conditional DELETE and its exact SQL for both admin and non-admin, zero-rows-as-denied (with no commit), missing-versus-denied, route enforcement for owner/stranger/admin/anonymous/id-None, a forged POST, the three log outcomes, and the cross markup in every state including the admin's view and the disabled-attribute prohibition.

- **Updated:** four existing delete tests, which used the old signature and an anonymous client that is now refused.
- **Suite result:** `pytest -m "not live"` — **296 passed** (was 273), 1 skipped, 6 deselected.

Manual & browser verification

Browser (375×812 and 1280×720), against the running app:

- Greyed cross renders muted (`rgb(91, 107, 122)`) with `cursor: default`; a genuine hover (`:hover` confirmed matching) leaves it muted on a transparent background — the red state is suppressed.
- Clicking a greyed cross opens the informational modal with the correct sentence, and **not** the delete confirmation.
- **Found and fixed while testing:** at 375px the informational dialog ran edge to edge, because `.modal-dialog`'s `max-width: 420px` comes after `.modal`'s `min(90vw, 900px)` and overrode it. Any dialog with long enough text had this latent; the longer sentence exposed it. Now `min(420px, 90vw)` — identical on desktop, and the dialog measures 338px wide with 19px margins on a phone, no horizontal page overflow, OK button 74×36.
- No console errors, no server errors.

Real database, four identities (sessions minted with the app's signing key, since JS cannot overwrite an `HttpOnly` session cookie):

Identity	Live crosses	Greyed message
anonymous	0 of 40	sign-in prompt
owner (id 7)	1 of 40 — digital, the one card they own	"created by admin or another user"
stranger (id 4242)	0 of 40	"created by admin or another user"
admin	40 of 40	—

Route enforcement, bypassing the UI entirely:

- Forged POST by a stranger for card 85 (owned by id 7) → refused.
- Same POST anonymously → refused with the sign-in prompt, database never touched.
- Regular user against unowned legacy card 6 (`added_by_user_id IS NULL`) → refused, `confirming = NULL` never matches and legacy cards are admin-only.
- Card count unchanged at 53 afterwards; cards 85 and 6 both still present. Nothing was deleted by any of it.
- All three refusals appear in `logs/cards.log` as `DELETE-DENIED` with the right reason and user.

Result

Pass. Every acceptance criterion in #162 met, including the forged-POST case.

Notes:

- The three `DELETE-DENIED` lines from this verification are real entries in the local `logs/cards.log` — accurate records of requests that genuinely happened, left in place rather

than edited out.

- #125 remains open: this delivers only the delete half of its rule. Adding and changing cards are still unrestricted for anonymous visitors.
- The greyed cross is now the visible consequence of #89's NULL legacy cards — 50 of the 53 belong to nobody and only the admin can remove them. That was called out in the issue as a one-way door and is worth re-reading before it ships.